

Università degli studi di Milano

Corso di Laurea Magistrale in Sicurezza Informatica

Sicurezza nelle Architetture Data Intensive

Titolo del progetto

Docente: Ernesto Damiani

Anno: I° Anno

Trimestre: III° Trimestre

Anno Accademico: 2025/2026

Componenti del gruppo:

Giuseppe Corasaniti - Matricola 84237A

Giuseppe Favata - Matricola 84231A

Matteo Toso - Matricola 85540A

Indice

1	Architettura del sistema	3
1.1	Ambito del sistema e integrazione con B4	3
1.2	Pipeline di elaborazione e decisione clinica	4
1.2.1	Stage 1 - Classificazione dell'urgenza con EfficientNet-B4	4
1.2.2	Stage 2 - Descrizione clinica con Qwen2-VL	4
1.2.3	Stage 3 - Recupero di casi clinici simili	5
1.2.4	Stage 4 - Sintesi clinica con BioMistral	5
1.2.5	Adaptation layer e assegnazione della priorità	5
1.3	Componenti persistenti, modelli e dipendenze esterne	6
1.3.1	Dataset e persistenza dei dati	6
1.3.2	Modelli e checkpoint	7
1.3.3	Ambiente di esecuzione e servizi esterni	7
1.4	Aggiornamento e validazione del sistema	7
1.4.1	Validazione clinica e raccolta del feedback	7
1.4.2	Evoluzione dei prompt	8
1.4.3	Retraining del classificatore EfficientNet-B4	8
1.4.4	Validazione tecnica e gestione delle versioni	8
2	Identificazione degli asset	10
2.1	Dati clinici e input	10
2.2	Inferenze e risultati della pipeline	11
2.3	Dataset e persistenza	11
2.4	Feedback e aggiornamento	12
2.5	Modelli e artefatti AI	13
2.6	Logica decisionale	14
2.7	Servizi applicativi e configurazione	15
3	Failure Mode and Effects Analysis	16
3.1	A01 – Immagine dermatologica	16
3.1.1	Funzioni e prerequisiti	16
3.1.2	Failure mode	17
3.2	A13 – Feedback clinico validato	17
3.2.1	Funzioni e prerequisiti	18
3.2.2	Failure mode	18
3.3	A16 – Modello EfficientNet-B4	19
3.3.1	Funzioni e prerequisiti	19
3.3.2	Failure mode	20
3.4	A20 – Regole dell'Adaptation Layer	21

3.4.1	Funzioni e prerequisiti	22
3.4.2	Failure mode	22
3.5	A21 – Piattaforma B4	23
3.5.1	Funzioni e prerequisiti	23
3.5.2	Failure mode	24
4	Security Properties e Threat Mapping	26
4.1	Proprietà di sicurezza CIA ³ -R	26
4.2	Mapping STRIDE-AI	26
4.2.1	A01 – Immagine dermatologica	27
4.2.2	A13 – Feedback clinico validato	28
4.2.3	A16 – Modello EfficientNet-B4	29
4.2.4	A20 – Regole dell’Adaptation Layer	30
4.2.5	A21 – Piattaforma B4	31
4.3	Mapping OWASP AI e Agentic AI	32
4.3.1	Applicabilità dei rischi Agentic AI	34

1. Architettura del sistema

DermaTriage è un sistema di triage dermatologico assistito da intelligenza artificiale, sviluppato nell'ambito del progetto AI vs Cancer. Il sistema elabora immagini di lesioni cutanee inviate dai pazienti insieme a informazioni cliniche e demografiche, con l'obiettivo di stimare il livello di urgenza del caso e assegnare una priorità clinica compresa tra P1 e P4.

DermaTriage è integrato con la piattaforma B4 (Social Things), che rappresenta il punto di interazione con il paziente e mette a disposizione le API utilizzate per lo scambio dei dati relativi ai consulti, ai documenti caricati, ai risultati diagnostici e alle validazioni mediche. L'elaborazione diagnostica viene invece eseguita dal servizio DermaTriage, che espone un'applicazione FastAPI e implementa una pipeline di intelligenza artificiale composta da quattro stadi, seguita da un adaptation layer responsabile della conversione del risultato nella scala clinica P1-P4.

1.1. Ambito del sistema e integrazione con B4

L'interazione con il paziente avviene attraverso la piattaforma B4, che raccoglie le informazioni necessarie per avviare il processo di triage. Nel flusso principale vengono acquisiti un'immagine della lesione cutanea, l'età del paziente, il sesso e la localizzazione anatomica della lesione. A questi dati possono aggiungersi informazioni relative alla sintomatologia, tra cui prurito, sanguinamento, crescita della lesione, cambiamenti morfologici e dolore.

Una volta raccolti i dati, DermaTriage accede alle informazioni associate alla richiesta attraverso le API messe a disposizione da B4. Il servizio può recuperare i consulti disponibili, individuare i documenti associati e scaricare l'immagine dermatologica necessaria all'elaborazione. Al termine della pipeline diagnostica, il risultato viene restituito a B4 e associato alla relativa richiesta di triage. La successiva validazione da parte del personale medico permette di ottenere un riscontro sull'esito prodotto dal sistema. Tali informazioni possono essere recuperate da DermaTriage e alimentare i meccanismi di aggiornamento del sistema, che comprendono l'evoluzione dei prompt e il retraining del classificatore EfficientNet-B4.

La comunicazione tra DermaTriage e B4 avviene tramite API REST protette da autenticazione. L'accesso ai servizi B4 utilizza un Bearer JWT ottenuto tramite l'endpoint `/api/v1/auth/token`; la gestione del token è affidata al componente `B4Auth`, che ne esegue il rinnovo automatico alla scadenza. I parametri necessari all'integrazione, tra cui credenziali, API key e indirizzo del servizio B4, sono configurati mediante variabili d'ambiente dedicate.

Il flusso integrato viene avviato attraverso l'endpoint `POST /diagnose`, al quale viene fornito un `consulto_id` come riferimento alla richiesta da elaborare. L'accesso a questo

endpoint richiede l'header `X-API-Key`, utilizzato anche per le funzionalità amministrative relative alla validazione delle diagnosi, alla gestione dei prompt e al retraining dei modelli.

Accanto al percorso integrato con B4, DermaTriage espone anche `POST /analyze`, che permette di avviare direttamente la pipeline fornendo un'immagine JPEG o PNG insieme a età, sesso e localizzazione. Questo secondo percorso consente quindi di utilizzare il motore diagnostico anche senza partire da una richiesta già presente sulla piattaforma B4.

Dal punto di vista architetturale, B4 e DermaTriage mantengono ruoli distinti. B4 gestisce l'interazione iniziale con il paziente e rende disponibili i dati necessari al processo di triage, mentre DermaTriage esegue l'elaborazione diagnostica e gestisce i meccanismi di aggiornamento dei modelli. L'integrazione tra i due sistemi è quindi bidirezionale e accompagna il caso clinico dalla fase di acquisizione fino alla restituzione e alla successiva validazione del risultato.

1.2. Pipeline di elaborazione e decisione clinica

L'elaborazione interna di DermaTriage si articola in quattro stadi che contribuiscono alla costruzione del risultato finale. L'architettura combina un classificatore visuale, un modello vision-language, un sistema di retrieval basato su casi clinici e un modello linguistico specializzato in ambito medico. Il risultato ottenuto viene successivamente trasformato nella priorità clinica utilizzata dal sistema.

1.2.1. Stage 1 - Classificazione dell'urgenza con EfficientNet-B4

Il primo stadio esegue una classificazione dell'immagine della lesione attraverso EfficientNet-B4, un modello convoluzionale sottoposto a fine-tuning per distinguere tre livelli di urgenza denominati `HIGH`, `MEDIUM` e `LOW`. L'immagine viene elaborata come input RGB di dimensione 380×380 pixel e il modello restituisce, oltre alla classe prevista, un valore di confidenza e le probabilità associate alle tre classi.

Per aumentare la sensibilità verso i casi considerati più urgenti, la classificazione `HIGH` utilizza una soglia operativa pari a 0.25. Questa prima valutazione non determina direttamente la priorità finale P1-P4, ma costituisce una delle informazioni utilizzate nelle fasi successive della pipeline.

1.2.2. Stage 2 - Descrizione clinica con Qwen2-VL

In parallelo alla classificazione dell'urgenza, l'immagine viene analizzata da Qwen2-VL-7B-Instruct. Il modello interpreta visivamente la lesione e genera una descrizione clinica testuale organizzata in cinque aspetti principali, relativi alla forma, ai bordi, al colore, alla texture e alla presenza di caratteristiche considerate sospette.

Questo passaggio trasforma quindi il contenuto visuale in una rappresentazione testuale strutturata. La descrizione prodotta non rappresenta ancora una decisione diagnostica,

ma viene utilizzata come query per la fase di ricerca dei casi clinici simili.

1.2.3. Stage 3 - Recupero di casi clinici simili

Il terzo stadio introduce un meccanismo di Retrieval-Augmented Generation basato su ChromaDB. La descrizione generata da Qwen2-VL viene convertita in una rappresentazione vettoriale mediante il modello `all-MiniLM-L6-v2` e confrontata con le descrizioni presenti nell'indice vettoriale.

La ricerca utilizza la similarità coseno e seleziona i cinque casi più vicini alla descrizione della lesione corrente. Per ciascun risultato vengono recuperate informazioni quali l'identificativo anonimizzato del paziente, la diagnosi associata, il livello di urgenza e il punteggio di similarità. In questo modo la pipeline affianca alla valutazione dell'immagine un riferimento a casi clinici precedenti con caratteristiche semanticamente simili.

1.2.4. Stage 4 - Sintesi clinica con BioMistral

Le informazioni prodotte nei primi tre stadi vengono successivamente aggregate e fornite a BioMistral-7B insieme ai dati relativi alla sintomatologia del paziente. Il modello riceve quindi la classificazione prodotta da EfficientNet-B4, la descrizione visuale generata da Qwen2-VL e i casi recuperati dal sistema RAG, disponendo di un contesto più ampio rispetto a quello disponibile nei singoli stadi precedenti.

BioMistral produce una risposta strutturata contenente il livello finale di urgenza, la relativa confidenza, una motivazione della decisione, l'azione raccomandata e una possibile patologia associata. Questo risultato rappresenta l'uscita della componente di inferenza vera e propria e viene successivamente elaborato dall'adaptation layer.

1.2.5. Adaptation layer e assegnazione della priorità

L'adaptation layer converte il livello di urgenza prodotto dalla pipeline nella scala P1-P4 utilizzata per il triage. La funzione `map_urgency_to_p_scale()` applica una serie di regole che tengono conto sia della classe di urgenza sia, per i casi `HIGH`, del livello di confidenza ottenuto.

Un risultato `HIGH` con confidenza superiore a 0.85 viene associato alla priorità P1, con un tempo previsto di presa in carico pari a 24 ore. Gli altri casi `HIGH` vengono assegnati a P2 con un intervallo di 48 ore, mentre le classi `MEDIUM` e `LOW` vengono convertite rispettivamente in P3, con 72 ore, e P4, con 7 giorni.

L'output finale comprende quindi la priorità P1-P4, il livello di confidenza, lo specialista indicato e il relativo SLA. L'adaptation layer separa in questo modo il risultato interno prodotto dai modelli dalla rappresentazione utilizzata per il triage clinico.

La Figura 1 riassume i principali componenti dell'architettura e il percorso seguito dalle informazioni durante l'elaborazione di una richiesta di triage.

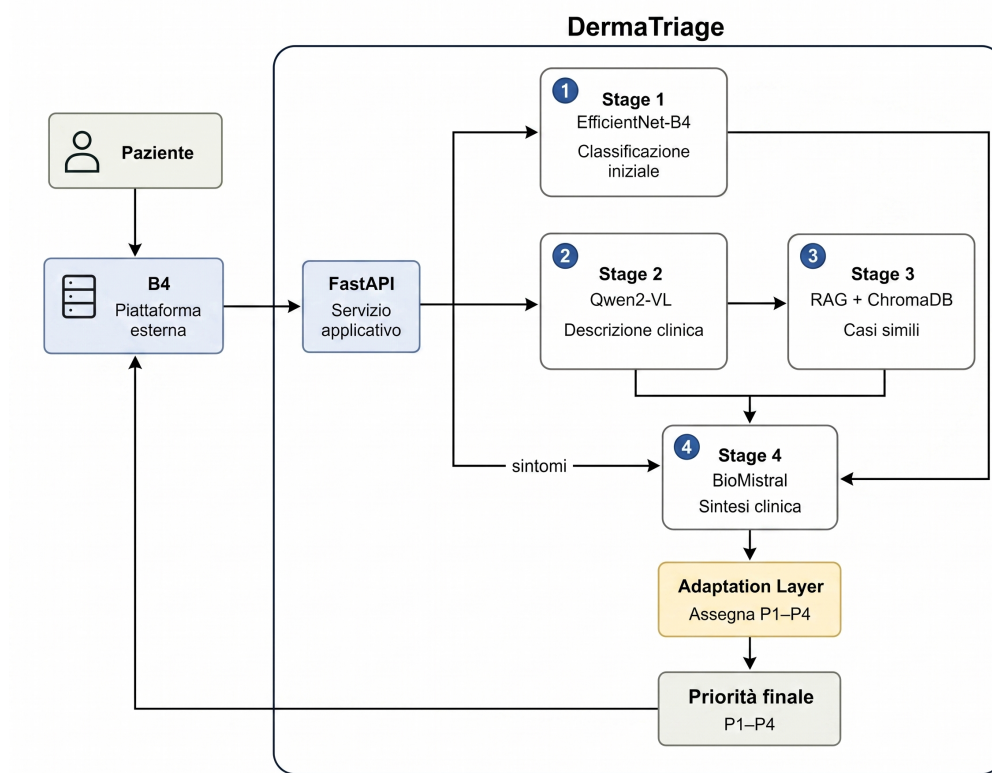


Figura 1: Architettura logica di DermaTriage e flusso principale di elaborazione

1.3. Componenti persistenti, modelli e dipendenze esterne

Oltre ai componenti coinvolti direttamente nel flusso di inferenza, DermaTriage utilizza diverse risorse persistenti per conservare i dati necessari al funzionamento della pipeline, i modelli e le informazioni prodotte durante l'esecuzione. Una parte di queste risorse viene utilizzata durante l'elaborazione delle richieste, mentre altre supportano la gestione e l'aggiornamento del sistema.

1.3.1. Dataset e persistenza dei dati

Il dataset utilizzato dal sistema RAG è conservato localmente nel file `RAG_dataset.csv` e contiene 2298 casi clinici derivati dal dataset pubblico ISIC. Le informazioni necessarie al retrieval vengono indicizzate in ChromaDB, il cui database vettoriale è mantenuto in modo persistente all'interno dell'ambiente DermaTriage.

Oltre alle risorse utilizzate dal RAG, il sistema conserva localmente le diagnosi prodotte, le correzioni effettuate durante la revisione dei risultati, le versioni dei prompt e le informazioni relative alle versioni dei modelli. Questi dati vengono utilizzati dalle funzionalità amministrative e dai meccanismi di aggiornamento del sistema.

Le immagini provenienti dalle richieste B4 vengono elaborate durante il processo di triage

senza essere aggiunte in modo permanente al dataset utilizzato dal sistema RAG. Quelle impiegate per l'addestramento sono invece conservate insieme ai relativi metadati, mentre file distinti definiscono gli insiemi impiegati nelle fasi di training, validation e test.

1.3.2. Modelli e checkpoint

I pesi del classificatore EfficientNet-B4 sono memorizzati localmente e caricati dal relativo checkpoint per l'esecuzione dell'inferenza. Il sistema mantiene inoltre i checkpoint prodotti dai successivi cicli di retraining e una copia di backup, così da supportare il versionamento del classificatore e il ripristino di una versione precedente quando necessario.

Qwen2-VL-7B-Instruct, BioMistral-7B e `all-MiniLM-L6-v2` vengono invece acquisiti tramite Hugging Face e caricati nell'ambiente di esecuzione di DermaTriage. Una volta disponibili localmente, vengono utilizzati direttamente dalla pipeline senza richiedere un servizio remoto di inferenza durante l'elaborazione dei casi clinici.

1.3.3. Ambiente di esecuzione e servizi esterni

DermaTriage è predisposto per l'esecuzione su un ambiente Linux dotato di GPU NVIDIA e supporto CUDA. L'applicazione FastAPI viene eseguita tramite Uvicorn ed espone le funzionalità necessarie all'accesso alla pipeline e alle operazioni amministrative. L'esecuzione dei modelli può avvenire anche su CPU, con tempi di elaborazione maggiori rispetto all'utilizzo dell'accelerazione GPU.

La principale interazione con un sistema esterno durante il funzionamento operativo rimane quella con B4. Attraverso le relative API, DermaTriage recupera i dati e i documenti necessari all'elaborazione, restituisce gli output diagnostici e può acquisire gli esiti clinici validati utilizzati nei processi di aggiornamento.

1.4. Aggiornamento e validazione del sistema

DermaTriage utilizza le correzioni raccolte durante la revisione dei risultati per aggiornare nel tempo alcuni componenti della pipeline. Il processo interessa sia i prompt utilizzati dai modelli generativi sia il classificatore EfficientNet-B4, attraverso due meccanismi distinti. Nel primo caso vengono aggiornati i prompt utilizzati dai modelli, mentre nel secondo vengono aggiornati i pesi del classificatore mediante un nuovo ciclo di fine-tuning.

1.4.1. Validazione clinica e raccolta del feedback

Le diagnosi prodotte da DermaTriage possono essere sottoposte a revisione da parte del personale medico. La validazione consente di confermare l'esito proposto dal sistema oppure di registrare una correzione, mantenuta come feedback associato alla diagnosi.

Gli esiti validati possono essere recuperati anche attraverso l'integrazione con B4. Le correzioni registrate alimentano due meccanismi distinti: l'evoluzione dei prompt utilizza

gli esempi corretti più recenti, mentre le discordanze tra l'esito del sistema e la valutazione medica vengono raccolte per il successivo retraining di EfficientNet-B4. I due meccanismi sono descritti rispettivamente nelle Sezioni 1.4.2 e 1.4.3.

1.4.2. Evoluzione dei prompt

L'aggiornamento dei prompt è gestito dal componente **PromptManager**. Il sistema tiene traccia delle correzioni effettuate durante la revisione delle diagnosi. L'aggiornamento viene attivato ogni dieci correzioni e utilizza una finestra scorrevole composta dai venti esempi più recenti.

Le diverse versioni vengono mantenute in modo persistente, permettendo di distinguere il prompt attualmente utilizzato da quelli prodotti in precedenza. Il meccanismo riguarda i prompt associati a Qwen2-VL e BioMistral e consente di modificarne le istruzioni mantenendo invariati i rispettivi parametri.

1.4.3. Retraining del classificatore EfficientNet-B4

Il retraining di EfficientNet-B4 viene attivato al raggiungimento di 50 correzioni associate a casi in cui l'esito prodotto dal sistema risulta discordante rispetto alla valutazione del personale medico. Il controllo viene eseguito tramite un trigger event-driven e il ciclo può essere avviato anche manualmente attraverso le funzionalità amministrative dedicate.

Per costruire i dati necessari al nuovo ciclo di addestramento, DermaTriage recupera tramite B4 i consulti e le relative immagini. Ai fini del retraining vengono utilizzati file JPEG e PNG, mentre i documenti PDF sono esclusi. Le priorità cliniche validate vengono ricondotte alle classi del classificatore secondo la corrispondenza P1/P2-HIGH, P3-MEDIUM e P4-LOW.

Il fine-tuning interessa gli ultimi due blocchi di feature extraction e la testa di classificazione di EfficientNet-B4. Ogni ciclo prevede 10 epoche, con learning rate pari a 5×10^{-6} per il backbone e 3×10^{-5} per il classificatore. I pesi di classe [3.0, 2.0, 1.0] assegnano maggiore importanza alla classe HIGH durante l'aggiornamento.

1.4.4. Validazione tecnica e gestione delle versioni

Prima che una nuova versione del classificatore sostituisca quella in uso, le sue prestazioni vengono confrontate con i valori di riferimento del modello precedente. La validazione considera in particolare la sensibilità sulla classe HIGH, la frequenza dei casi urgenti classificati erroneamente come LOW e l'accuratezza complessiva.

L'aggiornamento non deve peggiorare la sensibilità sui casi HIGH né aumentare i falsi LOW; inoltre, l'accuratezza complessiva non può diminuire di oltre cinque punti percentuali rispetto al riferimento. Come baseline vengono utilizzati una sensibilità HIGH del 90.24%, un tasso di falsi LOW del 7.93% e un'accuratezza complessiva dell'81.74%.

I checkpoint prodotti dai cicli di retraining vengono conservati come versioni distinte del classificatore. È inoltre previsto un checkpoint di backup della versione attiva, utilizzabile per ripristinare il modello precedente. Il rollback automatico è previsto nel caso in cui l'accuratezza della nuova versione diminuisca di oltre il 5% rispetto al modello attivo.

Le informazioni sulle diverse versioni e sulla cronologia dei cicli di retraining vengono mantenute in modo persistente, permettendo di ricostruire gli aggiornamenti effettuati nel tempo.

2. Identificazione degli asset

DermaTriage comprende diversi asset che concorrono al processo di triage e al mantenimento della pipeline nel tempo. Oltre ai dati clinici acquisiti per ciascun caso, rientrano tra gli asset le informazioni prodotte durante l'inferenza, i dataset e le strutture di persistenza, i modelli AI e gli artefatti utilizzati nei processi di aggiornamento e validazione.

Le dipendenze tra questi elementi consentono agli effetti di un eventuale malfunzionamento di propagarsi tra differenti stadi della pipeline. Gli asset comprendono quindi sia le risorse direttamente coinvolte nella determinazione della priorità clinica, sia quelle necessarie al recupero delle informazioni e all'evoluzione del sistema.

2.1. Dati clinici e input

Il processo di triage riceve come input l'immagine della lesione e le informazioni cliniche associate al paziente, tra cui età, sesso, localizzazione anatomica e sintomatologia disponibile. Nel flusso integrato con B4, ogni richiesta è inoltre associata a un consulto specifico, il cui identificativo consente di mantenere il corretto collegamento tra i dati acquisiti, l'elaborazione effettuata e il risultato prodotto da DermaTriage.

ID	Asset	Tipo	Funzione / utilizzo	Input / output	Fase
A01	Immagine dermatologica	Dato clinico grezzo	Fornisce l'informazione visiva della lesione utilizzata per la classificazione dell'urgenza e la generazione della descrizione clinica.	Input: immagine della lesione acquisita tramite B4 o <code>/analyze</code> . Output: fornita a EfficientNet-B4 e Qwen2-VL.	Acquisizione e inferenza
A02	Dati clinici, demografici e sintomatologia	Dato clinico strutturato	Fornisce il contesto clinico e demografico complementare all'immagine e contribuisce alla successiva elaborazione del caso.	Input: età, sesso, localizzazione anatomica e sintomatologia disponibile. Output: informazioni contestuali utilizzate nella pipeline; i sintomi alimentano la sintesi clinica di BioMistral.	Acquisizione e inferenza
A03	Identificativo del consulto	Metadato applicativo	Identifica la richiesta B4 e mantiene l'associazione tra il consulto, i dati elaborati e il relativo risultato.	Input: <code>consulto_id</code> ricevuto tramite <code>/diagnose</code> . Output: riferimento utilizzato per recuperare il caso e associare il risultato alla richiesta corrispondente.	Integrazione e gestione del caso

Tabella 1: Asset relativi ai dati clinici e agli input di DermaTriage.

2.2. Inferenze e risultati della pipeline

Durante l’inferenza, i diversi stadi della pipeline producono informazioni intermedie che vengono progressivamente combinate fino alla determinazione della priorità clinica finale. Tali risultati comprendono la classificazione iniziale dell’urgenza, la descrizione clinica della lesione, i casi simili recuperati dal sistema RAG e la successiva sintesi clinica.

ID	Asset	Tipo	Funzione / utilizzo	Input / output	Fase
A04	Classificazione di urgenza EfficientNet-B4	Inferenza del modello	Fornisce una prima valutazione dell’urgenza della lesione, utilizzata dagli stadi successivi della pipeline.	Input: immagine dermatologica. Output: classe HIGH, MEDIUM o LOW, confidence e probabilità associate.	Inferenza - Stage 1
A05	Descrizione clinica Qwen2-VL	Inferenza del modello	Produce una descrizione strutturata delle caratteristiche visibili della lesione, utilizzata per contestualizzare il caso.	Input: immagine dermatologica. Output: descrizione di forma, bordi, colore, texture e caratteristiche sospette della lesione.	Inferenza - Stage 2
A06	Casi clinici simili recuperati dal RAG	Informazione recuperata	Fornisce precedenti clinici semanticamente simili al caso corrente come supporto alla successiva sintesi clinica.	Input: descrizione clinica della lesione. Output: cinque casi simili con diagnosi, urgenza, similarità e relativo identificativo anonimizzato.	Inferenza - Stage 3
A07	Sintesi clinica BioMistral	Inferenza del modello	Integra i risultati degli stadi precedenti e la sintomatologia disponibile per formulare una valutazione clinica complessiva.	Input: risultati degli Stage 1-3 e sintomi. Output: urgenza finale, confidence, reasoning, azione raccomandata e patologia prevista.	Inferenza - Stage 4
A08	Risultato finale di triage	Output clinico	Esprime la priorità clinica restituita dal sistema e costituisce il risultato conclusivo del processo di triage.	Input: sintesi clinica e logica dell’Adaptation Layer. Output: priorità P1-P4 e informazioni associate al risultato.	Decisione finale

Tabella 2: Asset relativi alle inferenze e ai risultati prodotti dalla pipeline di DermaTriage.

2.3. Dataset e persistenza

DermaTriage utilizza diverse risorse persistenti per supportare il recupero dei casi clinici, l’addestramento e la valutazione del classificatore e la conservazione dei risultati prodotti

durante l'esecuzione. Questi asset comprendono sia dati strutturati sia rappresentazioni indicizzate utilizzate direttamente dalla pipeline.

ID	Asset	Tipo	Funzione / utilizzo	Input / output	Fase
A09	Dataset clinico RAG	Dataset clinico	Conserva i casi clinici utilizzati come base informativa per il retrieval dei casi simili e come base per la preparazione dei dati del classificatore.	Input: casi clinici strutturati con descrizione clinica, diagnosi, livello di urgenza e relativi metadati. Output: base informativa utilizzata per la costruzione dell'indice vettoriale ChromaDB e per la preparazione dei dati del classificatore.	Persistenza e preparazione dati
A10	Indice vettoriale ChromaDB	Indice vettoriale	Memorizza e indicizza le rappresentazioni vettoriali delle descrizioni cliniche, consentendo la ricerca per similarità semantica.	Input: embedding delle descrizioni cliniche indicizzate e embedding della query. Output: riferimenti ai cinque casi più simili e relativi valori di similarità, utilizzati dal sistema RAG per costruire il risultato del retrieval.	Persistenza e inferenza - Stage 3
A11	Dati di training, validation e test	Dataset ML	Supporta l'addestramento, la selezione del modello e la valutazione delle prestazioni di EfficientNet-B4.	Input: immagini, metadati e dati derivati dalla preparazione del dataset. Output: split distinti per training, validation e test utilizzati nel ciclo di sviluppo del modello.	Training e validazione
A12	Storico delle diagnosi	Dato persistente	Conserva localmente i risultati diagnostici prodotti da DermaTriage e ne supporta la consultazione e la gestione successiva.	Input: risultati prodotti dalle richieste di triage. Output: diagnosi archiviate e disponibili per la consultazione e per eventuali revisioni successive.	Persistenza dei risultati

Tabella 3: Asset relativi ai dataset e alle risorse persistenti di DermaTriage.

2.4. Feedback e aggiornamento

Il mantenimento della pipeline utilizza gli esiti della validazione clinica per aggiornare nel tempo alcuni dei suoi componenti. Le conferme e le correzioni effettuate dal personale

medico alimentano l'evoluzione dei prompt e, in caso di discordanza con il risultato prodotto dal sistema, il retraining di EfficientNet-B4. Le nuove versioni del classificatore sono inoltre sottoposte a criteri di validazione prima della loro adozione.

ID	Asset	Tipo	Funzione / utilizzo	Input / output	Fase
A13	Feedback clinico validato	Dato clinico validato	Raccoglie le conferme e le correzioni effettuate dal personale medico e fornisce il riferimento clinico utilizzato nei processi di aggiornamento del sistema.	Input: esito prodotto da DermaTriage e successiva validazione medica. Output: conferme o correzioni utilizzate per l'evoluzione dei prompt e, nei casi discordanti, per il retraining di EfficientNet-B4.	Validazione e aggiornamento
A14	Prompt e storico delle versioni	Artefatto AI	Contiene le istruzioni utilizzate da Qwen2-VL e BioMistral e conserva le relative versioni generate dal processo di evoluzione dei prompt.	Input: correzioni cliniche recenti utilizzate per aggiornare i prompt. Output: prompt aggiornati utilizzati dai modelli generativi durante l'inferenza.	Aggiornamento e inferenza
A15	Metriche e criteri di accettazione del modello	Artefatto di validazione	Definisce i riferimenti utilizzati per confrontare una nuova versione di EfficientNet-B4 con il modello attualmente in uso prima della sua adozione.	Input: prestazioni della nuova versione e valori di riferimento del modello attivo. Output: valutazione basata su sensibilità HIGH, falsi LOW e accuratezza complessiva, utilizzata nella decisione di adozione o rollback.	Validazione del modello

Tabella 4: Asset relativi al feedback clinico e ai processi di aggiornamento di DermaTriage.

2.5. Modelli e artefatti AI

La pipeline di DermaTriage utilizza più modelli con funzioni distinte e complementari. EfficientNet-B4 effettua la classificazione iniziale dell'urgenza, Qwen2-VL produce la descrizione clinica della lesione, BioMistral integra le informazioni disponibili nella sintesi clinica e all-MiniLM-L6-v2 genera le rappresentazioni vettoriali utilizzate dal sistema RAG. Al classificatore EfficientNet-B4 è inoltre associato il checkpoint contenente i parametri appresi utilizzati durante l'esecuzione.

ID	Asset	Tipo	Funzione / utilizzo	Input / output	Fase
A16	Modello EfficientNet-B4	Modello di classificazione	Analizza l'immagine dermatologica e fornisce la prima classificazione dell'urgenza utilizzata dagli stadi successivi della pipeline. Il suo comportamento è determinato dai parametri appresi durante l'addestramento e caricati dal checkpoint attivo.	Input: immagine dermatologica e parametri del modello caricati dal checkpoint. Output: classe HIGH, MEDIUM o LOW, confidence e probabilità associate.	Training e inferenza - Stage 1
A17	Modello Qwen2-VL	Modello multimodale	Analizza visivamente la lesione e genera una descrizione clinica strutturata utilizzata negli stadi successivi della pipeline.	Input: immagine dermatologica e prompt. Output: descrizione di forma, bordi, colore, texture e caratteristiche sospette della lesione.	Inferenza - Stage 2
A18	Modello BioMistral	Modello linguistico	Integra le informazioni prodotte dagli stadi precedenti e la sintomatologia disponibile per generare la sintesi clinica complessiva del caso.	Input: classificazione di urgenza, descrizione clinica, casi simili, sintomi e prompt. Output: urgenza finale, confidence, reasoning, azione raccomandata e patologia prevista.	Inferenza - Stage 4
A19	Modello all-MiniLM-L6-v2	Modello di embedding	Genera le rappresentazioni vettoriali delle descrizioni cliniche utilizzate per confrontare semanticamente il caso corrente con i casi indicizzati in ChromaDB.	Input: descrizione clinica testuale. Output: embedding utilizzato per la ricerca dei casi semanticamente simili.	Retrieval - Stage 3

Tabella 5: Asset relativi ai modelli e agli artefatti AI di DermaTriage.

2.6. Logica decisionale

Al termine della pipeline di inferenza, il risultato prodotto da BioMistral viene trasformato nella scala di priorità clinica utilizzata da DermaTriage. Questa conversione è regolata dall'Adaptation Layer, che applica criteri deterministici al livello di urgenza e alla relativa confidenza per assegnare la priorità finale da P1 a P4.

ID	Asset	Tipo	Funzione / utilizzo	Input / output	Fase
A20	Regole dell'Adaptation Layer	Logica decisionale	Converte il livello di urgenza prodotto dalla pipeline nella priorità clinica P1-P4 applicando le regole previste per il triage.	Input: livello di urgenza e relativa confidenza. Output: priorità P1-P4, specialista indicato e relativo SLA.	Decisione finale

Tabella 6: Asset relativo alla logica decisionale finale di DermaTriage.

2.7. Servizi applicativi e configurazione

L'esecuzione della pipeline di DermaTriage dipende anche dai servizi che gestiscono l'interazione con l'esterno e l'accesso alle funzionalità del sistema. La piattaforma B4 supporta lo scambio delle informazioni relative ai consulti, mentre il servizio applicativo FastAPI espone le funzionalità di DermaTriage. A questi componenti si affianca la configurazione operativa, che definisce i parametri e le credenziali necessari al loro funzionamento.

ID	Asset	Tipo	Funzione / utilizzo	Input / output	Fase
A21	Piattaforma B4	Servizio esterno	Gestisce l'interazione con il paziente e rende disponibili a DermaTriage le informazioni associate ai consulti, supportando inoltre la restituzione e la successiva validazione dei risultati.	Input: dati e documenti associati al consulto e risultati prodotti da DermaTriage. Output: informazioni del consulto, immagini e risultati validati accessibili a DermaTriage tramite API.	Acquisizione, integrazione e aggiornamento
A22	Servizio applicativo FastAPI	Servizio applicativo	Esponde le funzionalità di DermaTriage e gestisce le richieste necessarie all'accesso alla pipeline di inferenza e alle altre operazioni applicative.	Input: richieste ricevute attraverso gli endpoint applicativi. Output: attivazione delle operazioni richieste e restituzione dei relativi risultati.	Esecuzione e integrazione
A23	Configurazione operativa e credenziali	Artefatto di configurazione	Definisce i parametri necessari al caricamento delle risorse, all'esecuzione della pipeline e all'autenticazione verso i servizi protetti e la piattaforma B4.	Input: variabili d'ambiente relative a percorsi, modelli, parametri operativi e credenziali. Output: configurazione utilizzata dai componenti di DermaTriage durante esecuzione, integrazione e retraining.	Configurazione ed esecuzione

Tabella 7: Asset relativi ai servizi applicativi e alla configurazione di DermaTriage.

3. Failure Mode and Effects Analysis

La Failure Mode and Effects Analysis (FMEA) è una metodologia utilizzata per identificare le possibili modalità di guasto di un sistema e valutarne le conseguenze. L'analisi considera gli asset selezionati tra quelli individuati nell'Asset Model, concentrandosi sugli elementi maggiormente significativi per il funzionamento della pipeline di DermaTriage. Per ciascun asset vengono esaminate le funzioni svolte, i relativi prerequisiti e i possibili failure mode, individuandone le cause e gli effetti che possono propagarsi agli altri componenti del sistema.

I failure mode considerati possono derivare sia da condizioni accidentali sia da azioni intenzionali in grado di alterare il normale comportamento dell'asset. L'eventuale corrispondenza con specifiche minacce di sicurezza viene analizzata successivamente mediante STRIDE-AI.

3.1. A01 – Immagine dermatologica

L'asset A01 rappresenta l'immagine della lesione dermatologica acquisita per il caso clinico e utilizzata come principale informazione visiva della pipeline. L'immagine può essere recuperata nell'ambito del consulto gestito tramite B4 oppure fornita direttamente attraverso l'endpoint `/analyze`.

All'interno della pipeline, l'immagine viene utilizzata nello Stage 1 da EfficientNet-B4 per la classificazione iniziale dell'urgenza e nello Stage 2 da Qwen2-VL per la generazione della descrizione clinica della lesione. La correttezza e l'adeguatezza dell'immagine costituiscono quindi un prerequisito per le successive elaborazioni basate sull'informazione visiva.

3.1.1. Funzioni e prerequisiti

Le principali funzioni dell'asset e i prerequisiti necessari al loro svolgimento sono riportati nella Tabella 8.

ID	Funzione	Prerequisiti
F01.1	Rappresentazione visiva della lesione	Acquisizione di un'immagine che rappresenti in modo adeguato la lesione dermatologica oggetto del consulto.
F01.2	Associazione dell'immagine al caso clinico	Corretta corrispondenza tra l'immagine acquisita e il consulto o la richiesta di analisi a cui essa appartiene.
F01.3	Fornitura dell'input visivo alla pipeline di inferenza	Disponibilità dell'immagine in un formato utilizzabile e corretta trasmissione dell'input a EfficientNet-B4 nello Stage 1 e a Qwen2-VL nello Stage 2.

Tabella 8: Funzioni e prerequisiti dell'asset A01 – Immagine dermatologica.

3.1.2. Failure mode

Sulla base delle funzioni individuate vengono considerate le principali modalità con cui l'asset A01 può non svolgere correttamente il proprio compito, ovvero i failure mode.

ID	Failure mode	Possibili cause	Effetti
FM01.1	Immagine di qualità insufficiente	Sfocatura, illuminazione inadeguata, risoluzione insufficiente, presenza di artefatti oppure condizioni di acquisizione che rendono poco distinguibili le caratteristiche della lesione.	L'immagine non rappresenta con sufficiente chiarezza le caratteristiche della lesione, riducendo l'affidabilità delle elaborazioni di EfficientNet-B4 e Qwen2-VL.
FM01.2	Lesione rappresentata in modo incompleto o non adeguato	Inquadratura parziale, porzione rilevante della lesione esclusa dall'immagine oppure acquisizione di una regione cutanea che non consente di osservare adeguatamente la lesione di interesse.	I modelli ricevono una rappresentazione visiva incompleta e possono produrre una classificazione o una descrizione clinica non rappresentative della lesione effettiva.
FM01.3	Immagine associata al caso clinico errato	Errata associazione tra immagine e consulto, selezione del documento non corrispondente al caso oppure errore nella gestione del riferimento utilizzato per recuperare l'immagine.	La pipeline elabora un'immagine non coerente con le informazioni cliniche della richiesta, producendo inferenze riferite al caso errato.
FM01.4	Manipolazione intenzionale dell'immagine	Alterazione deliberata del contenuto visivo, introduzione di perturbazioni o modifica dell'immagine prima dell'invio alla pipeline con l'obiettivo di influenzare l'elaborazione dei modelli.	EfficientNet-B4 e Qwen2-VL ricevono un input apparentemente valido ma alterato, con possibile modifica della classificazione dell'urgenza o della descrizione clinica prodotta.
FM01.5	Immagine non disponibile o non utilizzabile dalla pipeline	Formato non supportato, file danneggiato, errore nella lettura, mancato recupero dal servizio di origine oppure errore durante il trasferimento.	EfficientNet-B4 e Qwen2-VL non dispongono di un input visivo utilizzabile e non possono completare normalmente le rispettive elaborazioni.

Tabella 9: Failure mode individuati per l'asset A01 – Immagine dermatologica.

3.2. A13 – Feedback clinico validato

L'asset A13 rappresenta il feedback clinico prodotto durante la revisione medica dei risultati generati da DermaTriage. Il feedback consente di confermare oppure correggere l'esito del sistema e viene associato al relativo caso clinico.

Le correzioni validate possono essere utilizzate nei meccanismi di aggiornamento della pipeline. In particolare, contribuiscono all'evoluzione dei prompt utilizzati dai modelli

generativi e, nei casi di disaccordo con la classificazione precedente, possono concorrere all'attivazione del retraining del classificatore EfficientNet-B4.

Il feedback clinico rappresenta quindi un collegamento diretto tra la revisione medica e il ciclo di aggiornamento del sistema.

3.2.1. Funzioni e prerequisiti

Le principali funzioni dell'asset e i prerequisiti necessari al loro svolgimento sono riportati nella Tabella 10.

ID	Funzione	Prerequisiti
F13.1	Rappresentazione dell'esito della revisione medica	Disponibilità del risultato diagnostico da revisionare e corretta associazione tra valutazione del medico e relativo caso clinico.
F13.2	Fornitura di esempi validati per l'aggiornamento dei prompt	Disponibilità di correzioni cliniche correttamente registrate e utilizzabili dal meccanismo di evoluzione dei prompt.
F13.3	Supporto al retraining del classificatore	Presenza di correzioni che evidenziano un disaccordo rispetto alla classificazione precedente e disponibilità dei relativi dati clinici necessari al processo di aggiornamento del modello.

Tabella 10: Funzioni e prerequisiti dell'asset A13 – Feedback clinico validato.

3.2.2. Failure mode

Sulla base delle funzioni individuate vengono considerate le principali modalità con cui l'asset A13 può non svolgere correttamente il proprio compito, ovvero i failure mode.

ID	Failure mode	Possibili cause	Effetti
FM13.1	Feedback contenente istruzioni o contenuti avversariali	Inserimento intenzionale nel feedback di testo costruito per influenzare i successivi meccanismi di evoluzione dei prompt oppure utilizzo di correzioni contenenti istruzioni non pertinenti al contenuto clinico.	Gli esempi utilizzati per aggiornare i prompt possono incorporare contenuti avversariali e influenzare il comportamento successivo di Qwen2-VL o BioMistral.
FM13.2	Feedback associato al caso clinico errato	Collegamento non corretto tra correzione e diagnosi, utilizzo di un identificativo del consulto errato oppure errore nella registrazione della relazione tra feedback e caso.	Una correzione valida può essere applicata a un caso differente, introducendo informazioni incoerenti nel ciclo di aggiornamento.
FM13.3	Feedback clinico incompleto o non disponibile	Mancata registrazione della revisione, campi necessari non valorizzati oppure indisponibilità della correzione nel momento in cui deve essere utilizzata.	I processi di aggiornamento dispongono di informazioni validate insufficienti e possono non attivarsi o operare su una base incompleta.
FM13.4	Feedback clinico alterato o non autentico	Modifica non autorizzata di una correzione registrata, sostituzione dell'esito validato oppure inserimento di feedback falsi da parte di un soggetto non autorizzato.	Il sistema può utilizzare informazioni manipolate per l'aggiornamento dei prompt o per il retraining, propagando l'alterazione alle versioni successive della pipeline.

Tabella 11: Failure mode individuati per l'asset A13 – Feedback clinico validato.

3.3. A16 – Modello EfficientNet-B4

L'asset A16 riguarda il modello EfficientNet-B4 utilizzato per la classificazione iniziale dell'urgenza dermatologica e i parametri appresi durante l'addestramento, caricati dal checkpoint attivo. A partire dall'immagine della lesione, il modello produce una classe di urgenza tra HIGH, MEDIUM e LOW, insieme alla confidence della classificazione e alle probabilità associate alle diverse classi.

Il risultato dello Stage 1 viene utilizzato dalle successive elaborazioni della pipeline e contribuisce alla sintesi clinica prodotta da BioMistral e alla successiva determinazione della priorità P1–P4.

3.3.1. Funzioni e prerequisiti

Le principali funzioni dell'asset e i prerequisiti necessari al loro svolgimento sono riportati nella Tabella 12.

ID	Funzione	Prerequisiti
F16.1	Estrazione delle caratteristiche visive	Disponibilità di un'immagine dermatologica acquisita correttamente (A01) e caricamento del modello con i relativi parametri.
F16.2	Classificazione dell'urgenza in HIGH, MEDIUM o LOW	Corretta elaborazione dell'immagine e utilizzo dei parametri previsti per la versione attiva del classificatore.
F16.3	Produzione della confidence e delle probabilità associate	Completamento corretto dell'inferenza e disponibilità dell'output numerico prodotto dal classificatore.
F16.4	Utilizzo della versione prevista del modello	Disponibilità del checkpoint attivo e corretta configurazione dei riferimenti utilizzati per il caricamento del modello (A23).

Tabella 12: Funzioni e prerequisiti dell'asset A16 – Modello EfficientNet-B4 e relativi pesi.

3.3.2. Failure mode

Sulla base delle funzioni individuate vengono considerate le principali modalità con cui l'asset A16 può non svolgere correttamente il proprio compito, ovvero i failure mode.

ID	Failure mode	Possibili cause	Effetti
FM16.1	Estrazione inadeguata delle caratteristiche visive	Qualità insufficiente dell'immagine, presenza di artefatti visivi oppure inquadratura non adeguata della lesione.	Le caratteristiche ricavate dall'immagine non rappresentano adeguatamente la lesione, compromettendo l'informazione utilizzata per determinare la classe di urgenza.
FM16.2	Classificazione errata dell'urgenza	Limiti di generalizzazione del modello, distribuzione dei casi operativi differente da quella osservata durante l'addestramento oppure insufficiente capacità discriminativa tra le classi.	Il modello può sovrastimare o sottostimare l'urgenza, propagando l'errore agli stadi successivi e contribuendo a una valutazione finale non appropriata.
FM16.3	Confidence o probabilità non coerenti con la classificazione	Calibrazione non adeguata delle probabilità oppure comportamento eccessivamente confidente su campioni incerti o poco rappresentativi.	Gli stadi successivi ricevono una stima non attendibile dell'incertezza associata alla classificazione.
FM16.4	Alterazione o sostituzione non autorizzata dei pesi o del checkpoint	Modifica deliberata dei parametri del modello, sostituzione del checkpoint attivo con una versione differente o compromessa, oppure caricamento di una versione non validata.	Il classificatore può produrre inferenze sistematicamente diverse da quelle previste pur continuando ad apparire operativo.
FM16.5	Output di inferenza incompleto o non disponibile	Errore durante l'esecuzione del modello, incompatibilità tra input, modello e parametri caricati oppure anomalia software che interrompe l'elaborazione prima del completamento.	Lo Stage 1 non fornisce classe, confidence o probabilità utilizzabili, impedendo agli stadi dipendenti di proseguire normalmente.

Tabella 13: Failure mode individuati per l'asset A16 – Modello EfficientNet-B4 e relativi pesi.

3.4. A20 – Regole dell'Adaptation Layer

L'asset A20 rappresenta l'insieme delle regole utilizzate dall'Adaptation Layer per convertire il livello di urgenza prodotto dalla pipeline nella scala clinica P1–P4 utilizzata dal sistema di triage.

La conversione considera la classe di urgenza HIGH, MEDIUM o LOW e, per i casi classificati come HIGH, anche il livello di confidence. Un caso HIGH con confidence superiore a 0.85 viene associato alla priorità P1, mentre gli altri casi HIGH vengono assegnati a P2. Le classi MEDIUM e LOW vengono convertite rispettivamente in P3 e P4.

L'Adaptation Layer produce inoltre le informazioni associate alla priorità finale, tra cui lo specialista indicato e il relativo SLA. Le regole di mapping costituiscono quindi il passaggio

conclusivo tra il risultato interno della pipeline di inferenza e la rappresentazione clinica restituita dal sistema.

3.4.1. Funzioni e prerequisiti

Le principali funzioni dell'asset e i prerequisiti necessari al loro svolgimento sono riportati nella Tabella 14.

ID	Funzione	Prerequisiti
F20.1	Traduzione dell'output di BioMistral nel risultato operativo di triage	Disponibilità di un output strutturato di BioMistral contenente il livello finale di urgenza e la relativa confidence, insieme alla corretta applicazione delle regole che determinano priorità P1–P4, specialista e SLA.
F20.2	Associazione delle indicazioni operative alla priorità assegnata	Disponibilità della priorità P1–P4 determinata e corretta corrispondenza con lo specialista e lo SLA previsti per il relativo livello di presa in carico.

Tabella 14: Funzioni e prerequisiti dell'asset A20 – Regole dell'Adaptation Layer.

3.4.2. Failure mode

Sulla base delle funzioni individuate vengono considerate le principali modalità con cui l'asset A20 può non svolgere correttamente il proprio compito, ovvero i failure mode.

ID	Failure mode	Possibili cause	Effetti
FM20.1	Interpretazione errata dell'output di BioMistral	Output strutturato incompleto o inatteso, errore nella lettura dei campi restituiti, utilizzo di un valore differente da final_urgency oppure gestione non corretta della confidence associata.	L'Adaptation Layer utilizza informazioni diverse da quelle effettivamente prodotte da BioMistral e può determinare una priorità P1–P4 non coerente con il risultato dello Stage 4.
FM20.2	Determinazione errata della priorità clinica	Definizione non corretta della corrispondenza tra HIGH, MEDIUM, LOW e P1–P4 oppure applicazione errata della soglia di confidence utilizzata per distinguere i casi P1 e P2.	Un output correttamente interpretato può essere trasformato in una priorità clinica diversa da quella prevista dalle regole dell'Adaptation Layer.
FM20.3	Alterazione intenzionale delle regole di mapping	Modifica non autorizzata della corrispondenza tra livelli di urgenza e priorità, variazione deliberata della soglia di confidence oppure sostituzione della logica di mapping prevista.	Il sistema può continuare a produrre risultati formalmente validi assegnando però sistematicamente priorità differenti da quelle previste.
FM20.4	Produzione incompleta o incoerente del risultato operativo	Mancata valorizzazione di priorità, specialista o SLA oppure associazione non coerente tra questi elementi nell'output prodotto dall'Adaptation Layer.	Il risultato finale del triage può risultare incompleto oppure contenere indicazioni operative non coerenti con la priorità assegnata.

Tabella 15: Failure mode individuati per l'asset A20 – Regole dell'Adaptation Layer.

3.5. A21 – Piattaforma B4

L'asset A21 rappresenta la piattaforma esterna B4, utilizzata come principale punto di interazione tra DermaTriage e il flusso clinico. Attraverso le API messe a disposizione dalla piattaforma, DermaTriage può recuperare i consulti e i relativi documenti, acquisire l'immagine dermatologica necessaria all'elaborazione e restituire il risultato diagnostico prodotto dalla pipeline.

B4 supporta inoltre la gestione delle validazioni mediche associate ai risultati di triage. Gli esiti clinici validati possono essere recuperati da DermaTriage e utilizzati nei meccanismi di aggiornamento del sistema, tra cui l'evoluzione dei prompt e il retraining del classificatore EfficientNet-B4. L'accesso alle API B4 avviene mediante autenticazione basata su Bearer JWT.

3.5.1. Funzioni e prerequisiti

Le principali funzioni dell'asset e i prerequisiti necessari al loro svolgimento sono riportati nella Tabella 16.

ID	Funzione	Prerequisiti
F21.1	Raccolta e organizzazione delle informazioni del consulto	Presenza di una richiesta di triage correttamente identificata e associazione coerente tra dati clinici, informazioni demografiche e documenti caricati dal paziente.
F21.2	Messa a disposizione dei dati necessari a DermaTriage	Presenza sulla piattaforma delle informazioni e dei documenti associati al consulto e disponibilità delle API necessarie al loro recupero.
F21.3	Conservazione del risultato diagnostico e della validazione medica	Corretta identificazione del consulto a cui associare il risultato prodotto da DermaTriage e l'eventuale successiva valutazione del personale medico.
F21.4	Supporto al ciclo di aggiornamento di DermaTriage	Disponibilità di consulti, immagini ed esiti clinici validati utilizzabili dai processi di aggiornamento dei componenti della pipeline.

Tabella 16: Funzioni e prerequisiti dell'asset A21 – Piattaforma B4.

3.5.2. Failure mode

Sulla base delle funzioni individuate vengono considerate le principali modalità con cui l'asset A21 può non svolgere correttamente il proprio compito, ovvero i failure mode.

ID	Failure mode	Possibili cause	Effetti
FM21.1	Dati del consulto incompleti o incoerenti	Informazioni cliniche mancanti, documenti non presenti, inconsistenza tra dati demografici, sintomi e documentazione oppure registrazione incompleta del consulto.	DermaTriage riceve una rappresentazione incompleta o incoerente del caso, riducendo l'affidabilità delle successive elaborazioni.
FM21.2	Manipolazione intenzionale dei dati o dei documenti del consulto	Modifica non autorizzata di informazioni cliniche, sostituzione dei documenti associati al consulto oppure alterazione dei riferimenti utilizzati per identificare il caso.	DermaTriage può elaborare informazioni intenzionalmente alterate o appartenenti a un caso differente, producendo un risultato di triage non corrispondente al caso reale.
FM21.3	Stato delle informazioni non correttamente aggiornato sulla piattaforma	Mancato aggiornamento del risultato diagnostico o della validazione, registrazione incompleta dello stato del consulto oppure persistenza di informazioni obsolete rispetto all'ultima elaborazione disponibile.	B4 può mantenere uno stato del caso non aggiornato, compromettendo la revisione medica o il successivo utilizzo del feedback clinico.
FM21.4	Servizi B4 non disponibili o non accessibili	Indisponibilità della piattaforma o delle API, problemi di autenticazione, mancato rilascio o rinnovo del Bearer JWT, interruzioni della comunicazione oppure sovraccarico intenzionale delle funzionalità esposte.	DermaTriage non può accedere alle funzionalità B4 necessarie, causando l'interruzione parziale o completa del flusso integrato.

Tabella 17: Failure mode individuati per l'asset A21 – Piattaforma B4.

4. Security Properties e Threat Mapping

I failure mode individuati nel capitolo precedente vengono utilizzati come punto di partenza per identificare le proprietà di sicurezza rilevanti e le eventuali minacce applicabili agli asset selezionati. L'analisi segue l'approccio STRIDE-AI, nel quale le proprietà di sicurezza vengono definite attraverso il modello CIA³-R e successivamente associate alle corrispondenti categorie STRIDE.

La presenza di un failure mode non implica tuttavia necessariamente l'esistenza di una minaccia. Alcune condizioni possono infatti derivare da errori, malfunzionamenti o limiti intrinseci del sistema, mentre altre possono essere prodotte o sfruttate intenzionalmente da un soggetto avversario. Il mapping STRIDE-AI viene quindi applicato soltanto quando il failure mode presenta una concreta possibile origine intenzionale.

4.1. Proprietà di sicurezza CIA³-R

Il modello CIA³-R considera sei proprietà di sicurezza: autenticità, integrità, non ripudiabilità, confidenzialità, disponibilità e autorizzazione. Nel contesto di DermaTriage tali proprietà vengono selezionate in funzione delle caratteristiche dell'asset e del failure mode considerato, senza assumere che tutte siano rilevanti per ciascun componente.

Proprietà	Significato	Categoria STRIDE
Authenticity	Possibilità di verificare l'origine dell'informazione o dell'output.	Spoofing
Integrity	Protezione da modifiche o inserimenti non autorizzati.	Tampering
Non-repudiation	Possibilità di attribuire un'operazione o un output senza che possa essere successivamente disconosciuto.	Repudiation
Confidentiality	Protezione delle informazioni da accessi o esposizioni non autorizzate.	Information Disclosure
Availability	Disponibilità dell'asset e capacità del sistema di produrre un output utile quando richiesto.	Denial of Service
Authorization	Utilizzo delle funzionalità e accesso agli output esclusivamente da parte di soggetti autorizzati.	Elevation of Privilege

Tabella 18: Proprietà CIA³-R e corrispondenza con le categorie STRIDE-AI.

4.2. Mapping STRIDE-AI

Per ciascun asset critico vengono analizzati i failure mode già individuati nella FMEA, identificando le proprietà CIA³-R coinvolte e distinguendo le condizioni accidentali da

quelle che possono derivare da un'azione intenzionale. Soltanto in quest'ultimo caso viene associata una categoria STRIDE-AI.

4.2.1. A01 – Immagine dermatologica

L'immagine dermatologica costituisce l'input visivo utilizzato da EfficientNet-B4 e Qwen2-VL. I failure mode relativi alla qualità o all'adeguatezza dell'acquisizione possono compromettere l'affidabilità dell'elaborazione senza implicare necessariamente un attaccante. Diversamente, la manipolazione deliberata dell'immagine costituisce una violazione dell'integrità, mentre la sua indisponibilità può assumere natura di Denial of Service qualora sia provocata intenzionalmente.

ID	Failure mode	CIA ³ -R	Natura	STRIDE-AI
FM01.1	Immagine di qualità insufficiente	Integrità in senso funzionale ¹	Prevalentemente accidentale	–
FM01.2	Lesione rappresentata in modo incompleto o non adeguato	Integrità in senso funzionale	Prevalentemente accidentale	–
FM01.3	Immagine associata al caso clinico errato	Integrity; Authenticity se l'associazione viene falsificata intenzionalmente	Accidentale o intenzionale	Tampering; eventualmente Spoofing
FM01.4	Manipolazione intenzionale dell'immagine	Integrity	Intenzionale	Tampering
FM01.5	Immagine non disponibile o non utilizzabile dalla pipeline	Availability	Accidentale o intenzionale	Denial of Service se intenzionale

Tabella 19: Mapping CIA³-R e STRIDE-AI dei failure mode dell'asset A01.

¹Con *integrità in senso funzionale* si indica che il dato non è sufficientemente corretto, completo o adeguato rispetto alla funzione che deve svolgere nella pipeline; ciò non implica necessariamente una violazione della proprietà *Integrity* nel significato STRIDE-AI.

4.2.2. A13 – Feedback clinico validato

Il feedback clinico validato rappresenta il riferimento utilizzato dai meccanismi di aggiornamento della pipeline, contribuendo sia all’evoluzione dei prompt sia, nei casi previsti, al retraining di EfficientNet-B4. La sua alterazione o manipolazione può quindi propagarsi alle versioni successive del sistema, mentre errori di associazione o indisponibilità possono verificarsi anche in assenza di un’azione avversaria.

ID	Failure mode	CIA ³ -R	Natura	STRIDE-AI
FM13.1	Feedback contenente istruzioni o contenuti avversariali	Integrity	Intenzionale	Tampering
FM13.2	Feedback associato al caso clinico errato	Integrity; Authenticity se l’associazione viene falsificata intenzionalmente	Accidentale o intenzionale	Tampering; eventualmente Spoofing
FM13.3	Feedback clinico incompleto o non disponibile	Availability	Prevalentemente accidentale; potenzialmente intenzionale	Denial of Service se intenzionale
FM13.4	Feedback clinico alterato o non autentico	Integrity; Authenticity	Intenzionale	Tampering; Spoofing

Tabella 20: Mapping CIA³-R e STRIDE-AI dei failure mode dell’asset A13.

4.2.3. A16 – Modello EfficientNet-B4

EfficientNet-B4 esegue la classificazione iniziale dell'urgenza dermatologica e produce la classe HIGH, MEDIUM o LOW insieme alla confidence e alle probabilità associate. Alcuni failure mode riguardano limiti prestazionali o comportamenti non affidabili del modello e possono verificarsi anche in assenza di un attaccante; altri, come la modifica dei pesi o del checkpoint attivo, costituiscono invece condizioni direttamente riconducibili a una compromissione intenzionale.

ID	Failure mode	CIA ³ -R	Natura	STRIDE-AI
FM16.1	Estrazione inadeguata delle caratteristiche visive	Integrità in senso funzionale	Prevalentemente accidentale	–
FM16.2	Classificazione errata dell'urgenza	Integrità in senso funzionale	Prevalentemente accidentale	–
FM16.3	Confidence o probabilità non coerenti con la classificazione	Integrità in senso funzionale	Prevalentemente accidentale	–
FM16.4	Alterazione o sostituzione non autorizzata dei pesi o del checkpoint	Integrity; Authenticity se viene sostituita la versione legittima del modello	Intenzionale	Tampering; eventualmente Spoofing
FM16.5	Output di inferenza incompleto o non disponibile	Availability	Accidentale o intenzionale	Denial of Service se intenzionale

Tabella 21: Mapping CIA³-R e STRIDE-AI dei failure mode dell'asset A16.

4.2.4. A20 – Regole dell’Adaptation Layer

Le regole dell’Adaptation Layer determinano la conversione del risultato prodotto da BioMistral nella priorità clinica P1–P4 e nelle relative indicazioni operative. Errori nell’interpretazione dell’output o nella logica di mapping possono verificarsi anche in assenza di un attaccante, mentre la modifica deliberata delle regole o delle soglie costituisce una compromissione diretta della logica decisionale. Anche la produzione di un risultato operativo incompleto o inutilizzabile può compromettere la disponibilità dell’output finale.

ID	Failure mode	CIA ³ -R	Natura	STRIDE-AI
FM20.1	Interpretazione errata dell’output di BioMistral	Integrità in senso funzionale	Prevalentemente accidentale	–
FM20.2	Determinazione errata della priorità clinica	Integrità in senso funzionale	Prevalentemente accidentale	–
FM20.3	Alterazione intenzionale delle regole di mapping	Integrity; Authorization se la modifica richiede privilegi non autorizzati	Intenzionale	Tampering; eventualmente Elevation of Privilege
FM20.4	Produzione incompleta o incoerente del risultato operativo	Availability	Prevalentemente accidentale; potenzialmente intenzionale	Denial of Service se intenzionale

Tabella 22: Mapping CIA³-R e STRIDE-AI dei failure mode dell’asset A20.

4.2.5. A21 – Piattaforma B4

La piattaforma B4 gestisce la raccolta e la disponibilità delle informazioni associate ai consulti, supportando inoltre la restituzione dei risultati diagnostici e delle successive validazioni mediche. I failure mode possono riguardare sia la qualità e coerenza delle informazioni mantenute sulla piattaforma, sia alterazioni intenzionali dei dati o indisponibilità dei servizi esposti tramite API.

ID	Failure mode	CIA ³ -R	Natura	STRIDE-AI
FM21.1	Dati del consulto incompleti o incoerenti	Integrità in senso funzionale	Prevalentemente accidentale	–
FM21.2	Manipolazione intenzionale dei dati o dei documenti del consulto	Integrity; Authenticity se vengono falsificati i riferimenti o l'origine dei dati	Intenzionale	Tampering; eventualmente Spoofing
FM21.3	Stato delle informazioni non correttamente aggiornato sulla piattaforma	Integrità in senso funzionale	Prevalentemente accidentale	–
FM21.4	Servizi B4 non disponibili o non accessibili	Availability; Authorization se l'accesso viene impedito o alterato tramite privilegi non autorizzati	Accidentale o intenzionale	Denial of Service; eventualmente Elevation of Privilege

Tabella 23: Mapping CIA³-R e STRIDE-AI dei failure mode dell'asset A21.

4.3. Mapping OWASP AI e Agentic AI

Il mapping STRIDE-AI viene completato confrontando le minacce individuate con i rischi descritti da OWASP per sistemi Machine Learning, applicazioni basate su modelli generativi e sistemi agentici. Le categorie OWASP vengono considerate solo quando descrivono una modalità di compromissione effettivamente pertinente all'architettura di DermaTriage.

Per i componenti di classificazione e per gli asset tipici di una pipeline Machine Learning viene considerato l'OWASP Machine Learning Security Top Ten, mentre per Qwen2-VL, BioMistral e i meccanismi basati su prompt viene utilizzato l'OWASP GenAI LLM Top 10. Il mapping ha quindi funzione complementare rispetto a STRIDE-AI e permette di caratterizzare in modo più specifico alcune minacce legate all'impiego di componenti AI.

Le principali corrispondenze individuate e i relativi impatti sul funzionamento di DermaTriage sono sintetizzati nella Tabella 24.

ID	Asset	Rischio OWASP	Impatto su DermaTriage
FM01.4	A01	ML01:2023 – Input Manipulation Attack; LLM01:2025 – Prompt Injection, per il ramo multimodale	La manipolazione dell’immagine può alterare le informazioni elaborate dai modelli e ridurre l’affidabilità della classificazione. Nel caso di Qwen2-VL, contenuti avversariali incorporati nell’immagine possono inoltre influenzare l’interpretazione multimodale. Ne risultano compromesse la sicurezza e l’affidabilità della pipeline, con possibile impatto sulla priorità clinica assegnata e quindi sulla clinical safety.
FM13.1	A13	LLM01:2025 – Prompt Injection; LLM04:2025 – Data and Model Poisoning, se il contenuto influenza in modo persistente l’evoluzione dei prompt	Istruzioni avversariali presenti nel feedback possono influenzare il comportamento dei modelli e, se incorporate nei successivi aggiornamenti dei prompt, propagare l’effetto alle elaborazioni future. Il rischio interessa quindi sicurezza, affidabilità e accountability del processo di aggiornamento e può riflettersi sulla sicurezza clinica delle decisioni successive.
FM13.4	A13	ML02:2023 – Data Poisoning Attack; LLM04:2025 – Data and Model Poisoning	Feedback alterati o non autentici possono contaminare i dati utilizzati per l’aggiornamento dei componenti della pipeline. La provenienza e l’affidabilità delle correzioni cliniche diventano quindi critiche per l’integrità del processo di retraining, la tracciabilità degli aggiornamenti e la qualità delle successive decisioni cliniche.
FM16.4	A16	ML10:2023 – Model Poisoning; ML06:2023 – ML Supply Chain Attacks, qualora la compromissione riguardi l’origine o la distribuzione del modello	L’alterazione dei pesi o la sostituzione del checkpoint modifica direttamente il comportamento di EfficientNet-B4. Una versione compromessa può produrre risultati apparentemente validi ma non affidabili, compromettendo sicurezza, reliability e accountability della versione distribuita e introducendo un rischio diretto per la clinical safety.
FM20.3	A20	ML09:2023 – Output Integrity Attack	La modifica delle regole che trasformano il risultato della pipeline nella scala P1–P4 altera il significato operativo dell’output anche quando i modelli a monte funzionano correttamente. Il rischio riguarda l’integrità della decisione, l’affidabilità e la tracciabilità della logica applicata e può modificare direttamente priorità e tempi di presa in carico del paziente.
FM21.2	A21	ML01:2023 – Input Manipulation Attack	La manipolazione dei dati o dei documenti del consulto può introdurre nella pipeline informazioni cliniche non affidabili. Poiché B4 costituisce una delle sorgenti degli input utilizzati durante il triage, la compromissione può propagarsi agli stadi successivi, incidendo sull’integrità del processo, sull’affidabilità del risultato e sulla sicurezza clinica.

Tabella 24: Mapping delle principali minacce di DermaTriage rispetto ai rischi OWASP AI e GenAI.

Per quanto riguarda la privacy, le minacce selezionate non evidenziano una violazione diretta della confidenzialità assimilabile a *Sensitive Information Disclosure*. L'impatto sulla privacy rimane pertanto secondario rispetto a integrità, affidabilità e sicurezza clinica e non viene introdotto un mapping OWASP specifico in assenza di un failure mode che descriva l'esposizione non autorizzata di dati clinici.

4.3.1. Applicabilità dei rischi Agentic AI

I rischi dell'OWASP Top 10 for Agentic Applications vengono considerati separatamente, poiché richiedono caratteristiche di autonomia che non sono attualmente presenti in DermaTriage. Qwen2-VL e BioMistral producono output all'interno di una pipeline orchestrata dall'applicazione, mentre l'Adaptation Layer applica regole deterministiche; i modelli non selezionano autonomamente strumenti, non pianificano sequenze di azioni e non operano direttamente su B4 o su altri sistemi esterni.

Alcune minacce individuate presentano comunque analogie con rischi agentici. La prompt injection di FM13.1 potrebbe evolvere verso *ASI01 – Agent Goal Hijack* qualora un modello compromesso fosse in grado di modificare autonomamente obiettivi o azioni della pipeline. Analogamente, la contaminazione persistente del contesto richiamerebbe *ASI06 – Memory & Context Poisoning* in presenza di una memoria agenticata utilizzata per guidare decisioni future.

Tali categorie non vengono tuttavia assegnate direttamente all'architettura attuale, poiché l'evoluzione dei prompt di DermaTriage non costituisce una memoria autonoma di un agente e i modelli non possiedono capacità di pianificazione o azione indipendente. L'introduzione futura di autonomia, tool calling o memoria persistente estenderebbe invece la superficie di attacco e renderebbe pertinente un'applicazione diretta delle categorie Agentic AI.